

Danh sách tính năng

48 nhóm · 353 tính năng · 4 thành viên

Khóa luận tốt nghiệp · Anti-Scam Platform

Sinh ngày 06/09/2026

Danh sách tính năng toàn hệ thống — Anti-Scam Platform

Ngày: 2026-09-06
Phạm vi: 48 nhóm tính năng · 353 tính năng · 4 thành viên · 12 nhóm/người
Kiến trúc tham chiếu: `Kien_truc_he_thong_v2.md`
Hợp đồng API: `API_Specification.md`
Thay thế: `Tong_hop_Feature_List_Week4.md` (bản Week 4, 4 slice)

⚠ Đọc mục này trước

Đây là **backlog đầy đủ**, không phải cam kết tiến độ. 353 tính năng vượt xa phạm vi một khóa luận cho nhóm 4 người. Vì vậy mỗi tính năng đều có nhãn ưu tiên:

Nhãn	Ý nghĩa	Ước lượng
P0	MVP bắt buộc — không có thì hệ thống không chạy được hoặc không demo được	103 tính năng
P1	Nên có — làm hệ thống hoàn chỉnh, làm nếu kịp	135 tính năng
P2	Mở rộng — viết vào chương "Hướng phát triển", làm nếu còn thời gian	115 tính năng

Cách dùng: khoá phạm vi bảo vệ ở `P0` + một phần `P1`. Toàn bộ `P2` đưa vào chương hướng phát triển của báo cáo — chúng vẫn có giá trị học thuật mà không cần code.

Ký hiệu thành phần: `api` Spring Boot · `worker` Spring Boot · `engine` Python scan-engine · `web` Next.js · `mobile` React Native · `ext` Browser Extension · `infra` hạ tầng

Phân bổ tổng quan

Người	Miền phụ trách	Nhóm	Thành phần chính
Hùng	Định danh, bảo mật, quyền riêng tư, lỗi chấm điểm & AI	H01–H12	<code>api</code> <code>engine</code> <code>web</code>
Khải	URL, tên miền, mạng, threat intel, hạ tầng & vận hành	K01–K12	<code>worker</code> <code>ext</code> <code>infra</code>
Kiên	Văn bản, rule, tri thức chống lừa đảo, trải nghiệm học	R01–R12	<code>engine</code> <code>api</code> <code>web</code>
Thắng	Thực thể, báo cáo cộng đồng, quản trị, mobile & UI	T01–T12	<code>api</code> <code>web</code> <code>mobile</code>

Chỉ mục nhanh

Hùng	Khải	Kiên	Thắng
H01 Đăng ký & kích hoạt	K01 Quét URL	R01 Phân tích nội dung	T01 Tra cứu số điện thoại
H02 Đăng nhập & phiên	K02 SSRF guard	R02 Trích xuất thực thể	T02 Tra cứu tài khoản NH

Hùng	Khải	Kiên	Thắng
H03 Hồ sơ & thiết lập	K03 Chuỗi chuyển hướng	R03 Thư viện mẫu lừa đảo	T03 QR code & VietQR
H04 RBAC & phân quyền	K04 SSL/TLS	R04 Quản trị Rule Engine	T04 Quản lý Risk Entity
H05 Audit log	K05 HTML & biểu mẫu	R05 Mô phỏng rule	T05 Gửi báo cáo cộng đồng
H06 Bảo mật nâng cao	K06 Typosquatting	R06 Phiên bản bộ rule	T06 Kiểm duyệt báo cáo
H07 Chống lạm dụng	K07 Threat intelligence	R07 Từ điển từ khoá	T07 Uy tín người báo cáo
H08 Quyền riêng tư	K08 Whitelist/Blacklist	R08 Hội thoại nhiều lượt	T08 Dashboard quản trị
H09 Tiền xử lý tiếng Việt	K09 Bảng chứng & ảnh chụp	R09 Thư viện kiến thức	T09 Thông báo & cảnh báo
H10 Rule engine & chấm điểm	K10 Browser Extension	R10 Trợ lý hỏi đáp	T10 Lịch sử quét
H11 Lớp LLM	K11 Hạ tầng & triển khai	R11 Quiz & gamification	T11 Ứng dụng mobile
H12 Đánh giá chất lượng	K12 CI/CD & giám sát	R12 i18n & a11y	T12 Chia sẻ & xuất báo cáo



HÙNG — Định danh, bảo mật & lỗi chấm điểm

Kế thừa Slice (1) Auth & User của Week 4, mở rộng sang **scan-engine** và lớp AI theo ADR-02/ADR-03.

H01 · Đăng ký & kích hoạt tài khoản

api web mobile · phụ thuộc: —

- **P0** Đăng ký bằng email + mật khẩu, validate định dạng và độ mạnh mật khẩu
- **P0** Hash mật khẩu bằng BCrypt cost ≥ 10 , không bao giờ ghi log
- **P0** Chặn trùng username/email bằng ràng buộc UNIQUE ở DB
- **P1** Xác thực email qua link kích hoạt có hạn 24 giờ
- **P1** Gửi lại email kích hoạt (có giới hạn tần suất)
- **P2** Đăng nhập bằng Google OAuth
- **P2** Chế độ dùng thử không cần tài khoản (guest scan, giới hạn lượt)

H02 · Đăng nhập & quản lý phiên

api web mobile · phụ thuộc: H01

- **P0** Đăng nhập trả JWT access token (TTL 15 phút) + refresh token (TTL 7 ngày)
- **P0** Lưu refresh token dạng hash trong DB, không lưu plain text
- **P0** Đăng xuất thu hồi refresh token của phiên hiện tại
- **P0** Refresh token rotation — cấp token mới, vô hiệu token cũ
- **P1** Phát hiện token reuse → thu hồi toàn bộ phiên của user
- **P1** Đăng xuất khỏi tất cả thiết bị
- **P2** Ghi nhớ đăng nhập trên thiết bị tin cậy

H03 · Hồ sơ & thiết lập cá nhân

api web · phụ thuộc: H02

- **P0** Xem hồ sơ: username, email, vai trò, ngày tham gia, số lượt quét
- **P0** Đổi mật khẩu (yêu cầu mật khẩu cũ, thu hồi toàn bộ refresh token sau khi đổi)
- **P1** Cập nhật tên hiển thị và ảnh đại diện
- **P1** Thiết lập ngưỡng cảnh báo cá nhân (nhảy / cân bằng / ít cảnh báo)
- **P1** Chọn ngôn ngữ và chủ đề giao diện
- **P2** Đặt liên hệ khẩn cấp để cảnh báo khi phát hiện lừa đảo nghiêm trọng

H04 · RBAC & phân quyền

api web · phụ thuộc: H02

- P0 Hai vai trò **USER** và **ADMIN**, lưu trong JWT payload
- P0 Bảo vệ toàn bộ route **/v1/admin/*** bằng kiểm tra vai trò, trả **403** rõ ràng
- P0 Middleware Next.js chặn **/admin/*** phía client
- P1 Vai trò **MODERATOR** chỉ được duyệt báo cáo, không sửa rule
- P1 Trang quản lý người dùng cho admin (danh sách, phân trang, lọc theo vai trò/trạng thái)
- P1 Khoá / mở khoá tài khoản, kèm lý do
- P2 Phân quyền chi tiết theo permission thay vì theo vai trò

H05 · Audit log & truy vết thao tác

api web · phụ thuộc: H04

- P0 Ghi log các thao tác nhạy cảm: đăng nhập, đổi mật khẩu, admin duyệt báo cáo, admin sửa rule
- P0 Bảng **audit_logs** chỉ INSERT, không UPDATE/DELETE (append-only)
- P0 Lưu **X-Request-Id** (correlation ID) trong mỗi bản ghi
- P1 Trang xem audit log cho admin, lọc theo user / hành động / khoảng thời gian
- P1 Ghi kèm IP và User-Agent
- P2 Xuất audit log ra CSV phục vụ điều tra
- P2 Cảnh báo khi phát hiện chuỗi thao tác bất thường

H06 · Bảo mật tài khoản nâng cao

api web mobile · phụ thuộc: H02

- P1 Xác thực hai lớp bằng TOTP (Google Authenticator)
- P1 Danh sách thiết bị đang đăng nhập, thu hồi từng thiết bị
- P1 Email cảnh báo khi đăng nhập từ thiết bị/vị trí lạ
- P2 Mã khôi phục dự phòng khi mất thiết bị 2FA
- P2 Đăng nhập sinh trắc học trên mobile (Face ID / vân tay)
- P2 Kiểm tra mật khẩu có nằm trong danh sách rò rỉ đã biết (k-anonymity)

H07 · Chống lạm dụng: rate limit, idempotency, chống bot

api · phụ thuộc: H02

- P0 Rate limit đăng nhập: 5 lần sai / IP / 15 phút, sau đó khoá 15 phút
- P0 Rate limit đăng ký: 5 request / phút / IP
- P0 Rate limit quét: 50/giờ khách, 200/giờ user đã đăng nhập, 500/giờ admin

- **P0** **Idempotency-Key** trên mọi **POST /v1/scan/***, lưu Redis TTL 24 giờ
- **P0** Trùng key nhưng khác request hash → trả **409 IDEMPOTENCY_KEY_CONFLICT**
- **P1** Trả **429** kèm header **Retry-After** và thông báo thân thiện
- **P2** CAPTCHA khi vượt ngưỡng nghi ngờ

H08 · Quyền riêng tư & vòng đời dữ liệu

api engine web · phụ thuộc: H03

- **P0** Không lưu mật khẩu, OTP, số thẻ, CVV của người dùng dưới bất kỳ dạng nào
- **P0** Che dữ liệu nhạy cảm trong log (số tài khoản → ******1234**, SĐT → **+849****678**)
- **P0** Người dùng xoá được lịch sử quét của mình
- **P1** Tự động xoá bản ghi quét cũ hơn N ngày (cấu hình được)
- **P1** Xuất toàn bộ dữ liệu cá nhân theo yêu cầu (data portability)
- **P1** Xoá tài khoản kèm xoá/ẩn danh toàn bộ dữ liệu liên quan
- **P2** Trang chính sách quyền riêng tư kèm nhật ký thay đổi

H09 · Chuẩn hoá & tiền xử lý văn bản tiếng Việt

engine · phụ thuộc: — ·  **đã có ở M1**

- **P0** Hạ chữ thường, bỏ dấu tiếng Việt, gộp khoảng trắng
- **P0** Gỡ leetspeak theo token có chứa chữ cái (**vi3tc0mb4nk** → **vietcombank**)
- **P0** So sánh hai mức chuẩn hoá để phát hiện cố tình né bộ lọc (fact **LEET_BRAND**)
- **P1** Chuẩn hoá dấu câu, emoji, ký tự Unicode đồng hình (homoglyph)
- **P1** Phát hiện chèn ký tự vô hình (zero-width space) để né bộ lọc
- **P2** Chuẩn hoá teencode và viết tắt tiếng Việt phổ biến
- **P2** Nhận diện ngôn ngữ đầu vào, cảnh báo khi không phải tiếng Việt

H10 · Rule engine & cơ chế chấm điểm

engine · phụ thuộc: H09 ·  **đã có ở M1**

- **P0** Mô hình rule khai báo bằng FACT: **requiresAll** / **requiresAny** / **requiresNone**
- **P0** Sinh **evidences[]** với **ruleCode**, **ruleName**, **score**, **severity**, **description**
- **P0** Cộng điểm, giới hạn **[0,100]**, ánh xạ sang **SAFE** / **CAUTION** / **DANGER**
- **P0** Bất biến: **riskScore** luôn bằng đúng tổng **evidences[].score** (có test khoá lại)
- **P0** Sinh **recommendation** gồm **action**, **message**, **reasons**, **nextSteps**
- **P1** Nạp rule từ PostgreSQL thay vì file JSON, cache Redis, vô hiệu cache khi admin sửa
- **P1** Tính **confidence** dựa trên số lượng và mức nghiêm trọng của evidence
- **P2** Điều chỉnh điểm theo ngưỡng cảnh báo cá nhân của người dùng (H03)

H11 · Lớp LLM & sinh giải thích tự nhiên

engine · phụ thuộc: H10

- **P1** Tích hợp LLM qua API ngoài, đặt sau interface `LlmProvider` để đổi nhà cung cấp bằng config
- **P1** Feature flag `ai.enabled` — tắt đi hệ thống vẫn chạy đủ, chỉ mất phần diễn giải
- **P1** LLM viết `explanation` và `recommendation` tiếng Việt tự nhiên
- **P1** Ràng buộc output bằng JSON Schema, retry 1 lần, hỏng thì trả kết quả rule
- **P1** Đóng góp điểm của LLM thành evidence riêng `source: "llm"`, trần cứng ± 15 điểm
- **P1** **Che PII trước khi gửi ra API ngoài** — số tài khoản, SĐT, OTP
- **P2** Chống prompt injection: bọc input trong delimiter, đối chiếu điểm LLM với điểm rule, lệch quá xa thì bỏ qua
- **P2** Cache kết quả LLM theo hash input để tiết kiệm quota
- **P2** Phương án dự phòng chạy mô hình cục bộ (Ollama) cho buổi bảo vệ

H12 · Đánh giá chất lượng mô hình

engine · phụ thuộc: H10, H11 · ★ **trọng tâm học thuật**

- **P0** Bộ test tự động cho từng rule, chạy trong CI
- **P1** Xây tập dữ liệu gán nhãn ~300–500 tin nhắn/URL tiếng Việt (scam / không scam)
- **P1** Script đo Precision / Recall / F1 / độ trễ cho 3 cấu hình: rule-only, LLM-only, hybrid
- **P1** Ma trận nhầm lẫn và danh sách case sai để phân tích nguyên nhân
- **P2** Tinh chỉnh trọng số rule dựa trên số liệu thay vì phỏng đoán
- **P2** Theo dõi tỷ lệ báo động giả trên dữ liệu thật sau khi triển khai
- **P2** So sánh với công cụ có sẵn (ChongLuaDao, PhishTank) trên cùng tập dữ liệu



KHẢI — URL, mạng, threat intel & vận hành

Kế thừa Slice (2) Scan URL & SSRF guard của Week 4. Là thành phần **duy nhất** được gọi ra Internet (ADR-03).

K01 · Quét URL & chuẩn hoá địa chỉ

api worker web · phụ thuộc: —

- **P0** `POST /v1/scan/url` theo pattern sync-first có leo thang (`200` hoặc `202` + `scanId`)
- **P0** Chuẩn hoá URL: thêm scheme, hạ chữ thường host, bỏ port mặc định, sắp xếp query
- **P0** Tách thành phần: scheme, subdomain, domain, TLD, path, query, fragment
- **P0** Cache kết quả theo `urlHash` , TTL 5 phút
- **P0** Phát hiện dấu hiệu cơ bản: dùng IP thay tên miền, URL quá dài, ký tự bất thường, `@` trong host
- **P1** Nhận diện dịch vụ rút gọn link và mở rộng về địa chỉ thật
- **P1** Trang kết quả chi tiết URL trên web, hiển thị từng bằng chứng
- **P2** Quét hàng loạt nhiều URL cùng lúc

K02 · SSRF guard & tầng fetch an toàn

worker · phụ thuộc: K01 · ★ **trọng tâm bảo mật**

- **P0** Chặn dải IP nội bộ: `127.0.0.0/8` , `10/8` , `172.16/12` , `192.168/16` , `169.254/16` , `::1` , `fc00::/7`
- **P0** Phân giải DNS trước, kiểm tra IP đích, rồi mới kết nối (chống DNS rebinding)
- **P0** Chỉ cho phép scheme `http` và `https`
- **P0** Giới hạn kích thước phản hồi và thời gian chờ, huỷ khi vượt ngưỡng
- **P0** Kiểm tra lại IP đích ở **mỗi** bước chuyển hướng, không chỉ URL đầu tiên
- **P1** Chạy fetch bằng user riêng, không có quyền truy cập DB
- **P1** Bộ test tấn công: `169.254.169.254` , `localhost` , redirect về IP nội bộ, DNS rebinding
- **P2** Tách tầng fetch ra container riêng có network policy giới hạn

K03 · Phân tích chuỗi chuyển hướng

worker · phụ thuộc: K02

- **P0** Theo redirect tối đa N bước (mặc định 5), ghi lại toàn bộ chuỗi
- **P0** Cảnh báo khi chuỗi quá dài hoặc có vòng lặp
- **P1** Phát hiện chuyển hướng đổi tên miền gốc (cross-domain redirect)
- **P1** Phát hiện chuyển hướng từ HTTPS xuống HTTP (downgrade)
- **P1** Bắt cả chuyển hướng bằng JavaScript và thẻ `<meta refresh>`

- **P2** Hiển thị trực quan chuỗi chuyển hướng trên giao diện
- **P2** Phát hiện cloaking — trả nội dung khác nhau theo User-Agent

K04 · Kiểm tra SSL/TLS & chứng chỉ

worker · phụ thuộc: K02

- **P0** Kiểm tra có HTTPS hay không
- **P0** Kiểm tra chứng chỉ còn hạn và khớp tên miền
- **P1** Trích xuất tổ chức phát hành, ngày cấp, ngày hết hạn
- **P1** Cảnh báo chứng chỉ tự ký hoặc mới cấp trong vài ngày
- **P1** Kiểm tra các HTTP security header (HSTS, CSP, X-Frame-Options)
- **P2** Tra Certificate Transparency log để tìm chứng chỉ khả nghi của thương hiệu
- **P2** Cảnh báo bộ mã hoá TLS yếu

K05 · Phân tích HTML & biểu mẫu công khai

worker · phụ thuộc: K02

- **P0** Parse HTML bằng Jsoup, trích xuất toàn bộ `<form>` và `<input>`
- **P0** Phát hiện input nhạy cảm: password, OTP, PIN, CVV, số thẻ, CCCD, số tài khoản
- **P0** Cảnh báo `form action` trỏ sang tên miền khác hoặc không dùng HTTPS
- **P1** Tìm từ khoá lừa đảo trong nội dung công khai của trang
- **P1** Phát hiện trang sao chép giao diện thương hiệu (logo, favicon, tiêu đề)
- **P1** Phát hiện iframe ẩn và input bị che
- **P2** So khớp mã nguồn trang với bộ kit phishing đã biết
- **P2** Phát hiện obfuscated JavaScript

K06 · Phát hiện typosquatting & giả mạo thương hiệu

worker engine · phụ thuộc: K01 ·  **một phần đã có ở M1**

- **P0** So khoảng cách Levenshtein giữa tên miền và danh sách thương hiệu
- **P0** Phát hiện tên miền lộ ra thương hiệu sau khi gỡ leetspeak
- **P1** Phát hiện ký tự đồng hình Unicode (homoglyph, tên miền IDN)
- **P1** Phát hiện thương hiệu nằm ở subdomain (`vietcombank.kẻ-gian.com`)
- **P1** Phát hiện thêm/bớt dấu gạch nối, đảo ký tự, thêm từ (`-verify` , `-secure`)
- **P2** Quản lý danh sách thương hiệu qua trang admin
- **P2** Tra tuổi tên miền qua WHOIS, cảnh báo tên miền mới đăng ký

K07 · Nạp dữ liệu threat intelligence

worker infra · phụ thuộc: K08

- P1 Nhập danh sách đen từ file CSV/JSON
- P1 Tích hợp nguồn công khai (PhishTank, OpenPhish, danh sách của ChongLuaDao)
- P1 Lập lịch cập nhật định kỳ, ghi phiên bản dataset vào risk_sources
- P1 Khử trùng lặp và hợp nhất khi nhiều nguồn cùng báo một tên miền
- P2 Ghi nguồn gốc và độ tin cậy cho từng bản ghi
- P2 Cho phép quay lại phiên bản dataset trước khi nạp sai
- P2 Xuất ngược danh sách của hệ thống cho cộng đồng dùng

K08 · Quản lý whitelist / blacklist tên miền

api web · phụ thuộc: H04

- P0 Danh sách trắng tên miền tin cậy để giảm báo động giả
- P0 Danh sách đen tên miền đã xác minh là lừa đảo
- P1 Trang admin quản lý: thêm, sửa, xoá, tìm kiếm, phân trang
- P1 Nhập hàng loạt từ file, kèm xem trước trước khi áp dụng
- P1 Vô hiệu hoá cache Redis khi danh sách thay đổi
- P1 Ghi audit log mọi thay đổi danh sách
- P2 Đặt hạn hiệu lực cho từng bản ghi
- P2 Quy trình khiếu nại gỡ khỏi danh sách đen

K09 · Bảng chứng & ảnh chụp trang

worker infra · phụ thuộc: K02

- P1 Lưu HTML thô của trang tại thời điểm quét làm bằng chứng
- P1 Chụp ảnh màn hình trang bằng headless browser
- P1 Lưu file vào object storage (MinIO / S3-compatible)
- P1 Sinh URL tạm có hạn để xem bằng chứng
- P2 Bấm nội dung để chứng minh bằng chứng không bị sửa
- P2 Tự động xoá bằng chứng sau N ngày
- P2 So sánh ảnh chụp với trang thật của thương hiệu

K10 · Browser Extension

ext · phụ thuộc: K01

- P2 Extension Chrome/Edge cảnh báo khi truy cập tên miền trong danh sách đen

- **P2** Chèn nhãn an toàn cạnh link trong kết quả tìm kiếm và mạng xã hội
- **P2** Chuột phải vào link để quét ngay
- **P2** Chặn trang nguy hiểm bằng màn hình cảnh báo có nút bỏ qua
- **P2** Đồng bộ lịch sử quét với tài khoản
- **P2** Chế độ ngoại tuyến dùng danh sách đen tải sẵn

K11 · Hạ tầng, Docker & triển khai

infra · phụ thuộc: —

- **P0** `docker-compose.yml` cho dev: postgres, redis, scan-engine, api
- **P0** Dockerfile cho từng service, dùng multi-stage build
- **P0** Cấu hình hoàn toàn qua biến môi trường, không hardcoded, không commit khoá
- **P0** Endpoint `/health` và `/ready` trên cả ba service
- **P1** `docker-compose.prod.yml` kèm Nginx và TLS Let's Encrypt
- **P1** Thêm RabbitMQ và MinIO khi tới mốc cần (M4)
- **P1** Script khởi tạo và migration cơ sở dữ liệu (Flyway/Liquibase)
- **P1** Sao lưu và phục hồi PostgreSQL định kỳ
- **P2** Triển khai lên EC2/VPS bằng script một lệnh

K12 · CI/CD, kiểm thử tự động & giám sát

infra · phụ thuộc: K11

- **P0** GitHub Actions chạy test của cả 3 service trên mỗi pull request
- **P0** Chặn merge khi test đỏ
- **P1** Kiểm tra định dạng và lint (Checkstyle, ruff, ESLint)
- **P1** Đo độ phủ test, hiển thị badge
- **P1** Log có cấu trúc (JSON) kèm `X-Request-Id` xuyên suốt mọi hop
- **P1** Quét lỗ hổng phụ thuộc (Dependabot / OWASP Dependency-Check)
- **P2** Metrics Prometheus + dashboard Grafana
- **P2** Cảnh báo khi tỷ lệ lỗi hoặc độ trễ vượt ngưỡng
- **P2** Tự động build và đẩy image khi merge vào `main`



KIÊN — Văn bản, rule & tri thức chống lừa đảo

Kế thừa Slice (3a) của Week 4. Theo ADR-03, Kiên làm **Rule Admin ở Java** — phần đánh giá rule chạy trong `engine`, phần quản trị chạy trong `api`.

R01 · Phân tích nội dung tin nhắn & bài đăng

`engine` `api` `web` · phụ thuộc: H09 · ☒ một phần đã có ở M1

- `P0` `POST /v1/scan/text` đồng bộ, tối đa 5000 ký tự
- `P0` Khớp từ khoá theo 6 nhóm: khẩn cấp, giả danh, thông tin nhạy cảm, chuyển tiền, quá tốt để tin, mời việc làm
- `P0` Nhận diện mẫu tổ hợp: giả mạo ngân hàng, giả danh cơ quan, trúng thưởng, tuyển CTV, shipper giả
- `P0` Trang quét nội dung trên web, hiển thị điểm và bằng chứng
- `P1` Hỗ trợ chọn nguồn tin (SMS / Zalo / Messenger / Email / Facebook) và điều chỉnh trọng số theo nguồn
- `P1` Đánh dấu trực quan đoạn văn bản đã kích hoạt rule
- `P2` Phân tích ảnh chụp màn hình tin nhắn bằng OCR
- `P2` Phân tích tệp email `.eml` gồm cả header

R02 · Trích xuất thực thể trong văn bản

`engine` · phụ thuộc: H09 · ☒ đã có ở M1

- `P0` Trích xuất URL (kể cả không có scheme) và địa chỉ IP
- `P0` Trích xuất số điện thoại Việt Nam, chuẩn hoá về `+84...`
- `P0` Trích xuất số tài khoản ngân hàng, không nhầm với số điện thoại
- `P0` Trích xuất số tiền (`500k`, `100 triệu`, `1.000.000đ`)
- `P0` Trích xuất mã OTP theo ngữ cảnh từ khoá
- `P1` Trích xuất tên ngân hàng và mã ngân hàng
- `P1` Trích xuất mốc thời gian và hạn chót ("trong vòng 24h")
- `P2` Trích xuất địa chỉ ví tiền mã hoá

R03 · Thư viện mẫu lừa đảo (taxonomy)

`engine` `api` `web` · phụ thuộc: R01

- `P0` Định nghĩa và phân loại các mẫu lừa đảo phổ biến tại Việt Nam
- `P1` Mỗi mẫu có mã, tên, mô tả, dấu hiệu nhận biết, ví dụ thật
- `P1` Gán nhãn loại lừa đảo vào kết quả quét

- **P1** Trang tra cứu các mẫu lừa đảo cho người dùng
- **P2** Thống kê mẫu nào đang phổ biến theo thời gian
- **P2** Cho phép admin thêm mẫu mới không cần sửa code
- **P2** Ánh xạ mẫu sang khung phân loại quốc tế

R04 · Quản trị Rule Engine

api web · phụ thuộc: H04, H10

- **P0** Bảng `risk_rules` và `rule_conditions` trong PostgreSQL
- **P0** `scan-engine` nạp rule từ DB thay vì file, cache Redis
- **P1** Trang admin: liệt kê, tìm kiếm, lọc rule theo danh mục và mức nghiêm trọng
- **P1** Tạo, sửa, bật/tắt rule qua giao diện
- **P1** Chinh trọng số và mức nghiêm trọng, kích hoạt rebuild cache
- **P1** Ghi audit log mọi thay đổi rule
- **P2** Sao chép rule để tạo biến thể
- **P2** Nhập/xuất bộ rule dạng JSON

R05 · Thử nghiệm & mô phỏng rule

api web · phụ thuộc: R04

- **P1** `GET /v1/rules/evaluate/preview` — chạy thử rule trên văn bản mẫu, không ghi lịch sử
- **P1** Giao diện sandbox: nhập văn bản, xem rule nào khớp và cộng bao nhiêu điểm
- **P1** Xem trước ảnh hưởng khi đổi trọng số, trước khi lưu
- **P2** Chạy rule mới trên tập dữ liệu gán nhãn, báo số case bị ảnh hưởng
- **P2** So sánh hai phiên bản bộ rule trên cùng tập đầu vào
- **P2** Chế độ shadow — chạy rule mới song song nhưng chưa áp dụng điểm

R06 · Phiên bản & rollback bộ rule

api web · phụ thuộc: R04

- **P1** Đánh phiên bản cho mỗi lần thay đổi bộ rule
- **P1** Lưu phiên bản rule đã dùng vào từng bản ghi kết quả quét
- **P1** Xem lịch sử thay đổi của một rule (ai sửa, sửa gì, khi nào)
- **P2** Quay lại phiên bản trước bằng một thao tác
- **P2** So sánh khác biệt giữa hai phiên bản
- **P2** Phê duyệt hai bước cho thay đổi rule quan trọng

R07 · Quản lý từ điển từ khoá tiếng Việt

api web engine · phụ thuộc: R04

- P0 Nhóm từ khoá lưu trong cấu hình, tự chuẩn hoá khi nạp
- P1 Trang admin quản lý nhóm từ khoá và từng từ khoá
- P1 Thêm/xoá từ khoá không cần deploy lại
- P1 Cảnh báo khi thêm từ khoá quá phổ thông dễ gây báo động giả
- P2 Gợi ý từ khoá mới từ các báo cáo cộng đồng đã duyệt
- P2 Hỗ trợ biểu thức chính quy cho từ khoá nâng cao
- P2 Từ điển đồng nghĩa và biến thể viết tắt

R08 · Phân tích đoạn hội thoại nhiều lượt

engine web · phụ thuộc: R01

- P1 Nhận đầu vào là nhiều tin nhắn có thứ tự, không chỉ một đoạn
- P1 Nhận diện kịch bản leo thang: làm quen → tạo lòng tin → yêu cầu tiền
- P1 Tính điểm cho cả hội thoại, không chỉ từng tin nhắn rời
- P2 Nhận diện mẫu lừa đảo tình cảm và đầu tư dài ngày
- P2 Cảnh báo khi hội thoại chuyển hướng sang yêu cầu tài chính
- P2 Dòng thời gian trực quan của hội thoại kèm điểm rủi ro theo từng bước

R09 · Thư viện kiến thức chống lừa đảo

api web mobile · phụ thuộc: R03

- P1 Bài viết hướng dẫn nhận biết từng loại lừa đảo
- P1 Danh mục theo chủ đề, có tìm kiếm
- P1 Gợi ý bài viết liên quan ngay trong trang kết quả quét
- P2 Trang admin soạn và xuất bản bài viết
- P2 Cảnh báo xu hướng lừa đảo mới theo tuần
- P2 Nội dung dạng thẻ ngăn cho người lớn tuổi, chữ to, ít thuật ngữ

R10 · Trợ lý hỏi đáp chống lừa đảo

engine web mobile · phụ thuộc: H11, R09

- P2 Giao diện hỏi đáp: "Tin nhắn này có phải lừa đảo không?"
- P2 Trả lời dựa trên thư viện kiến thức, có trích dẫn nguồn
- P2 Gợi ý hành động tiếp theo tùy tình huống người dùng mô tả
- P2 Bàn giao sang biểu mẫu báo cáo khi xác định là lừa đảo

- **P2** Giới hạn phạm vi trả lời, từ chối câu hỏi ngoài lĩnh vực
- **P2** Ghi nhận câu hỏi thường gặp để bổ sung vào thư viện

R11 · Bài kiểm tra & gamification

api **web** **mobile** · phụ thuộc: R09

- **P2** Bài trắc nghiệm "Bạn có nhận ra tin nhắn lừa đảo không?"
- **P2** Chấm điểm và giải thích từng câu sai
- **P2** Huy hiệu theo mốc: số lần quét, số báo cáo được duyệt
- **P2** Bảng xếp hạng đóng góp cộng đồng
- **P2** Chuỗi ngày sử dụng liên tục
- **P2** Chia sẻ kết quả bài kiểm tra lên mạng xã hội

R12 · Quốc tế hoá & khả năng tiếp cận

web **mobile** · phụ thuộc: —

- **P1** Tách toàn bộ chuỗi giao diện ra file ngôn ngữ, mặc định tiếng Việt
- **P1** Tương phản màu và cỡ chữ đạt WCAG AA
- **P1** Điều hướng được hoàn toàn bằng bàn phím
- **P1** Không truyền đạt thông tin chỉ bằng màu (kèm biểu tượng và chữ cho SAFE/CAUTION/DANGER)
- **P2** Bản dịch tiếng Anh
- **P2** Nhãn ARIA và kiểm thử với trình đọc màn hình
- **P2** Chế độ chữ lớn dành cho người cao tuổi

THẮNG — Thực thể, cộng đồng, quản trị & mobile

Kế thừa Slice (3b) của Week 4, nhận thêm Slice (4) Community Report + Admin Dashboard vốn chưa có chủ.

T01 · Tra cứu số điện thoại

api web mobile · phụ thuộc: T04

- P0 POST /v1/scan/phone , chuẩn hoá về +84xxxxxxxxxx
- P0 Tra risk_entities và số lượt bị báo cáo
- P0 Tính điểm theo: có trong danh sách đen, số báo cáo, số báo cáo đã xác minh
- P1 Suy giảm điểm theo thời gian — báo cáo cũ có trọng số thấp hơn
- P1 Cache Redis TTL 15 phút cho số tra cứu nhiều
- P1 Che số điện thoại khi ghi log và khi hiển thị công khai
- P2 Nhận diện đầu số dịch vụ, đầu số quốc tế bất thường
- P2 Nhận diện số giả mạo tổng đài ngân hàng

T02 · Tra cứu số tài khoản ngân hàng

api web mobile · phụ thuộc: T04

- P0 POST /v1/scan/bank-account , chuẩn hoá số tài khoản và mã ngân hàng
- P0 Validate mã ngân hàng theo danh sách ngân hàng Việt Nam
- P0 Tra risk_entities và các báo cáo liên quan
- P1 Cache Redis TTL 15 phút
- P1 Che số tài khoản khi ghi log (****1234)
- P1 Cảnh báo khi tên chủ tài khoản không khớp với tên người bán được nhắc tới
- P2 Nhóm các báo cáo cùng một số tài khoản để thấy quy mô
- P2 Cảnh báo tài khoản xuất hiện trong nhiều vụ khác nhau

T03 · Quét QR code & VietQR

api web mobile · phụ thuộc: T02, K01

- P0 POST /v1/scan/qr nhận qrData đã giải mã từ thiết bị
- P0 Phân loại nội dung QR: URL / VietQR / văn bản thường / không xác định
- P0 Định tuyến: URL → quét URL, VietQR → tra tài khoản, văn bản → phân tích nội dung
- P0 Parse VietQR lấy mã ngân hàng, số tài khoản, số tiền, nội dung chuyển khoản

- **P0** QR chứa URL bắt buộc đi qua SSRF guard
- **P1** Giải mã QR từ ảnh tải lên trên web
- **P1** Cảnh báo QR bị dán đè lên QR thật (so với lịch sử quét cùng địa điểm)
- **P2** Cảnh báo khi số tiền trong QR khác số tiền người dùng dự kiến

T04 · Quản lý Risk Entity

api web · phụ thuộc: H04

- **P0** Bảng **risk_entities** cho tên miền, URL, số điện thoại, số tài khoản, từ khoá, thương hiệu
- **P0** Trạng thái: **SUSPECTED**, **VERIFIED**, **CLEARED**
- **P0** Tạo/cập nhật entity khi một báo cáo được duyệt
- **P1** Trang admin quản lý entity: tìm kiếm, lọc theo loại và trạng thái, phân trang
- **P1** Xem toàn bộ báo cáo dẫn tới một entity
- **P1** Gộp các entity trùng lặp
- **P2** Điểm tin cậy của entity dựa trên số nguồn độc lập xác nhận
- **P2** Tự động hạ trạng thái entity không còn báo cáo mới trong thời gian dài

T05 · Gửi báo cáo lừa đảo (cộng đồng)

api web mobile · phụ thuộc: H02

- **P0** **POST /v1/reports** với loại thực thể, giá trị, mô tả
- **P0** Rate limit 10 báo cáo / ngày / user
- **P0** Nút "Gửi báo cáo" ngay trong trang kết quả quét, điền sẵn dữ liệu
- **P1** Đính kèm file bằng chứng (ảnh chụp màn hình), giới hạn dung lượng và định dạng
- **P1** Chọn loại lừa đảo theo taxonomy (R03)
- **P1** Xem trạng thái các báo cáo mình đã gửi
- **P2** Báo cáo ẩn danh không cần đăng nhập, có CAPTCHA
- **P2** Cảnh báo trùng lặp khi entity đã được báo cáo

T06 · Kiểm duyệt báo cáo

api web · phụ thuộc: T05, H04

- **P0** Trạng thái báo cáo: **PENDING**, **UNDER_REVIEW**, **VERIFIED**, **REJECTED**, **NEED_MORE_INFO**, **RESOLVED**
- **P0** Hàng đợi duyệt cho admin, sắp xếp theo mức độ và thời gian
- **P0** Duyệt báo cáo → tạo/cập nhật **risk_entities**
- **P0** Ghi audit log mọi thao tác duyệt
- **P1** Xem chi tiết báo cáo kèm bằng chứng và kết quả quét liên quan
- **P1** Duyệt hàng loạt các báo cáo cùng một entity
- **P1** Ghi lý do khi từ chối, gửi thông báo cho người báo cáo

- **P2** Tự động ưu tiên báo cáo từ người có uy tín cao
- **P2** Phân công báo cáo cho từng moderator

T07 · Uy tín người báo cáo & chống spam

api · phụ thuộc: T06

- **P1** Tính điểm uy tín dựa trên tỷ lệ báo cáo được duyệt
- **P1** Hạ uy tín khi báo cáo bị từ chối nhiều lần
- **P1** Phát hiện báo cáo trùng lặp và báo cáo hàng loạt bất thường
- **P2** Người uy tín cao được duyệt nhanh hoặc tự động duyệt
- **P2** Tạm khoá quyền báo cáo khi uy tín xuống dưới ngưỡng
- **P2** Huy hiệu người đóng góp tích cực
- **P2** Phát hiện nhóm tài khoản phối hợp báo cáo sai sự thật

T08 · Dashboard thống kê quản trị

api **web** · phụ thuộc: H04, T06

- **P1** Số lượt quét theo ngày/tuần/tháng, tách theo loại đầu vào
- **P1** Phân bố mức rủi ro **SAFE** / **CAUTION** / **DANGER**
- **P1** Top loại lừa đảo phổ biến
- **P1** Top tên miền, số điện thoại, số tài khoản bị báo cáo nhiều nhất
- **P1** Số báo cáo theo trạng thái, thời gian xử lý trung bình
- **P2** Biểu đồ xu hướng theo thời gian, so sánh kỳ trước
- **P2** Bản đồ nhiệt theo khung giờ trong ngày
- **P2** Xuất dashboard ra PDF theo kỳ

T09 · Thông báo & cảnh báo

api **worker** **web** **mobile** · phụ thuộc: T06

- **P1** Thông báo trong ứng dụng khi báo cáo được duyệt hoặc bị từ chối
- **P1** Email thông báo kết quả xử lý báo cáo
- **P1** Worker gửi email bất đồng bộ, retry 3 lần rồi đẩy vào dead-letter queue
- **P1** Trung tâm thông báo, đánh dấu đã đọc
- **P2** Push notification trên mobile
- **P2** Cảnh báo chủ động khi entity người dùng từng quét bị nâng lên **DANGER**
- **P2** Bản tin tuần về xu hướng lừa đảo mới

T10 · Lịch sử quét & quản lý dữ liệu cá nhân

api web mobile · phụ thuộc: H02

- P0 GET /v1/scan/history — chỉ trả bản ghi của chính người dùng
- P0 GET /v1/scan/{scanId} với kiểm tra quyền sở hữu, trả 404 thay vì 403
- P0 Phân trang bằng cursor
- P1 Lọc theo loại đầu vào, mức rủi ro, khoảng thời gian
- P1 Xoá từng bản ghi hoặc xoá toàn bộ lịch sử, kèm xoá bằng chứng
- P1 Đánh dấu và ghi chú cho bản ghi quan trọng
- P2 Quét lại một mục cũ để xem điểm đã thay đổi chưa
- P2 Xuất lịch sử ra CSV

T11 · Ứng dụng mobile

mobile · phụ thuộc: T01, T02, T03

- P0 Màn hình đăng nhập, lưu token vào Secure Storage (không dùng AsyncStorage thường)
- P0 Màn hình nhập liệu 4 tab: URL, văn bản, số điện thoại, số tài khoản
- P0 Trình quét QR bằng camera, **giải mã trên thiết bị**, chỉ gửi qrData lên server
- P0 Share Target nhận link và văn bản từ Zalo/Messenger/SMS, tự định tuyến theo nội dung
- P0 **Không** đọc SMS, notification, call log, danh bạ hay clipboard ngầm; **không** dùng Accessibility Service
- P1 Màn hình kết quả rút gọn, nêu 3–5 lý do chính
- P1 Dán nhanh từ clipboard khi ứng dụng đang mở (do người dùng chủ động bấm)
- P2 Widget quét nhanh trên màn hình chính
- P2 Chế độ ngoại tuyến dùng danh sách đen tải sẵn

T12 · Thư viện UI dùng chung, chia sẻ & xuất báo cáo

web mobile worker · phụ thuộc: T10

- P0 Component RiskResultCard dùng chung cho mọi loại kết quả quét
- P0 Hiển thị nhất quán: điểm, mức, màu, biểu tượng, danh sách bằng chứng, khuyến nghị
- P1 Thành phần hiển thị bằng chứng có thể mở rộng/thu gọn từng rule
- P1 Chia sẻ kết quả quét qua link công khai có hạn, đã che dữ liệu nhạy cảm
- P1 Xuất kết quả quét ra PDF (worker chạy bất đồng bộ)
- P2 Sinh ảnh tóm tắt kết quả để chia sẻ lên mạng xã hội
- P2 Nhúng widget tra cứu vào website khác
- P2 Xuất báo cáo thống kê theo ngày/tuần/tháng cho admin

Bảng cân đối khối lượng

Người	Nhóm	P0	P1	P2	Tổng
Hùng	12	32	32	21	85
Khải	12	27	36	28	91
Kiên	12	13	30	38	81
Thắng	12	31	37	28	96
Tổng	48	103	135	115	353

Hai điểm lịch cần lưu ý khi chốt phạm vi:

- **Kiên chỉ có 13 P0** vì phần lõi rule đã hoàn thành ở mốc M1. Bù lại nhóm này gánh nhiều P2 nhất (38) — chủ yếu là tri thức, trợ lý hỏi đáp, gamification. Nếu muốn cân bằng thật thì nên nâng một số P2 của Kiên lên P1, hoặc chuyển bớt P0 của Thắng sang cho Kiên (ví dụ T04 Risk Entity).
- **Thắng có 31 P0 và 96 tính năng** — nặng nhất, vì nhận thêm Slice (4) vốn chưa có chủ. Nếu nhóm không tuyển thêm người thì nên san bớt T08 (Dashboard) hoặc T09 (Thông báo) sang Kiên.

Ghi chú triển khai

1. **Đây là backlog, không phải kế hoạch.** Trước khi code, mỗi người chốt lại tập P0 của mình và ước lượng thời gian thật. Nếu tổng P0 vượt quá thời gian còn lại thì hạ tiếp phạm vi — hạ sớm tốt hơn hạ muộn.
2. **Ranh giới ngôn ngữ theo ADR-03:** Khải, Kiên, Thắng viết Java cho phần I/O và trạng thái. Chỉ Hùng viết Python trong scan-engine.
3. **Phụ thuộc chéo cần chú ý:** T04 (Risk Entity) là đầu vào của T01, T02, T03 và cả K08. Nếu T04 trễ thì bốn nhóm khác không có dữ liệu để chấm điểm. Đây là đường găng của dự án.
4. **Mọi thay đổi hợp đồng API** phải sửa trong contracts/openapi/ trước, theo ADR-07 — đó là cơ chế tránh code đè lên nhau.
5. **Trạng thái**  **đã có ở M1** áp dụng cho H09, H10, R01 (một phần), R02, K06 (một phần) — xem services/scan-engine/.

Người soạn: Hùng · Ngày 2026-09-06 · Chờ nhóm rà soát và chốt phạm vi P0